

[LOGO AREA]

AMMAR ALZAIEM

CYBERSECURITY | VAPT

SECURITY ASSESSMENT REPORT

Automated scan – Task 28

REPORT ID	AZ-WEB-2026-028
VERSION	1.0
ASSESSMENT DATE	28/9/2026
REPORT DATE	28/9/2026
PREPARED BY	Ammar Alzaiem
CLASSIFICATION	Public

I used nikto on DVWA, and it returned the following:

```
(ammar@noOne) - [~]
$ nikto -h http://192.168.56.2/dvwa
- Nikto v2.5.0

+ Target IP: 192.168.56.2
+ Target Hostname: 192.168.56.2
+ Target Port: 80
+ Start Time: 2026-09-28 13:29:19 (GMT3)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /dvwa/: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /dvwa/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /dvwa/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /dvwa/: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /dvwa/: Cookie security created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /dvwa redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /dvwa/robots.txt: Server may leak inodes via ETags, header found with file /dvwa/robots.txt, inode: 93164, size: 26, mtime: Tue Mar 16 07:56:22 2010. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /dvwa/index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /dvwa/config/: Directory indexing found.
+ /dvwa/config/: Configuration information may be available remotely.
+ /dvwa/?=PHPB885F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /dvwa/?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /dvwa/?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /dvwa/?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /dvwa/login/: This might be interesting.
+ /dvwa/docs/: Directory indexing found.
+ /dvwa/CHANGELOG.txt: A changelog was found.
+ /dvwa/login.php: Admin login page/section found.
+ /dvwa/?-s: PHP allows retrieval of the source code via the -s parameter, and may allow command execution. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-1823
+ /dvwa/login.php?-s: PHP allows retrieval of the source code via the -s parameter, and may allow command execution. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-1823
+ /dvwa/CHANGELOG.txt: Version number implies that there is a SQL Injection in Drupal 7, which can be used for authentication bypass (Drupalgeddon). See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3704 https://www.sektioneins.de/advisories/advisory-012014-drupal-pre-auth-sql-injection-vulnerability.html
+ 8101 requests: 0 error(s) and 24 item(s) reported on remote host
+ End Time: 2026-09-28 13:29:34 (GMT3) (15 seconds)

+ 1 host(s) tested
```

Confirmed Findings

- Source code disclosure via **/dvwa/?-s** and **/dvwa/login.php?-s**
- Cross-site-Tracing(XST): HTTP method is active
- Directory Indexing: Information leakage via enabled indexes on **/dvwa/config** and **/dvwa/docs/**

False Positive Findings

- Drupal SQL Injection: **/dvwa/CHANGELOG.txt**: Version number implies that there is a SQL Injection in Drupal

Informational Findings

- PHPSESSID and security cookies missing the HttpOnly flag.
- Allowed HTTP Methods: OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
- Uncommon Header: /dvwa/index: Uncommon header 'tcn' found, with contents: list.
-